Computers & Security 154 (2025) 104456

Contents lists available at ScienceDirect

Computers & Security

journal homepage: www.elsevier.com/locate/cose

Full length article

Security risk assessment in IoT environments: A taxonomy and survey

Mofareh Waqdan [a],*, Habib Louafi [b], Malek Mouhoub [a]

[a] Department of Computer Science, University of Regina, Regina, SK, Canada
[b] Department of Science and Technology, TELUQ University, Montreal, QC, Canada

ARTICLE INFO

Keywords:
Security risk assessment
Security risk management
Internet of Things (IoT)
IoT attacks

ABSTRACT

Internet of Things (IoT) applications have become an integral part of our daily lives. However, due to the rising number of cybercrimes, ensuring cyberspace security has become essential. The security and privacy of IoT applications are fundamental as they are used in critical sectors, like healthcare, transportation systems, and energy production. As a result, many studies are focusing on the security and privacy of the IoT revolution. The need for assessing IoT security risks is increasing.

This paper presents a survey and taxonomy of risk management, analysis, and evaluation methods applied to systems involving IoT devices. In particular, the paper reviews and categorizes existing IoT risk management and assessment frameworks, and the different assessments techniques, risk perspectives, and methodologies. The paper concludes with a deep analysis of these frameworks, solutions, and guidelines, and discusses future research directions.

1. Introduction

Keeping up with the rapid growth and complexity of the network revolution requires greater attention to data security. According to a recent report by Cybersecurity Ventures, global cybercrime damages are expected to reach $10.5 trillion annually by 2025, up from $3 trillion in 2015 (Cybersecurity Ventures, 2022)., which are a deliberate attempt to compromise private and sensitive information. In light of the increasing number of cybercrimes being committed every day, the need for cyberspace security has become imperative. The Internet of Things (IoT) revolution is now the focus of study, and security and privacy are acknowledged as the primary challenges for IoT applications, primarily due to several critical vulnerabilities, including authentication weaknesses, data integrity risks, and device-level vulnerabilities. Authentication issues arise from weak or hardcoded credentials, making unauthorized access a major concern. Data integrity threats arise from insecure communication protocols and insufficient encryption, which expose IoT systems to the risk of data tampering. Additionally, device vulnerabilities, such as outdated firmware and unpatched security flaws, leave IoT devices susceptible to exploitation and malware attacks.

Using the traditional internet in a different way, IoT allows any physical device or gadget used in our daily lives to be connected to the internet or to one another in order to exchange data or perform certain duties through the network (Kumar et al., 2019). As a dynamic global infrastructure for the technical area, the IoT connects smart devices so that the internet is used as a medium for continuous data transfer and connectivity between things (Ray, 2018).

IoT is made up of smart devices that operate under various constraints and share data in numerous ways among surroundings that communicate with each other or the internet. Technically speaking, the IoT ecosystem may include any electronic or physical device that has an IP and/or MAC address and is linked to a network (Radanliev et al., 2018). In this IoT ecosystem, data integrity, availability, accessibility, and confidentiality are major concerns for manufacturers and users alike (Tariq et al., 2023). The IoT stack includes four layers, namely application, middleware (also called data preprocessing), network, and sensing (Shameli-Sendi et al., 2016; Sikder et al., 2018), as shown in Fig. 1.

There are various security risks in the sensing layer since the sensed data is stored in clear (not encrypted), either in the cloud or locally. Communication between IoT devices in the network layer is known to be vulnerable to attacks. Malicious applications installed on IoT devices can cause firmware performance degradation at the middleware layer. It would then be possible to carry out an assault on outdated and not patched IoT device's firmware. Operating systems' backdoors, which can be created by malicious applications, could lead to security concerns at the application layer.

The combination of the chance of an unwanted event and its severity level is referred to as *cyber risk*. The National Institute of Standards and Technology (NIST) defines risk as the probability that a specific

* Corresponding author.
E-mail address: Maw105@uregina.ca (M. Waqdan).

https://doi.org/10.1016/j.cose.2025.104456
Received 8 January 2025; Received in revised form 14 March 2025; Accepted 20 March 2025
Available online 29 March 2025
0167-4048/© 2025 The Authors. Published by Elsevier Ltd. This is an open access article under the CC BY license (http://creativecommons.org/licenses/by/4.0/).

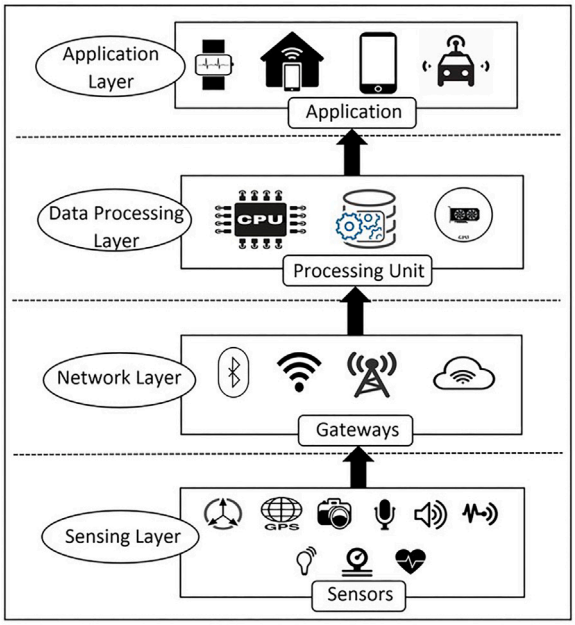

Fig. 1. IoT architecture stack (Sikder et al., 2018).

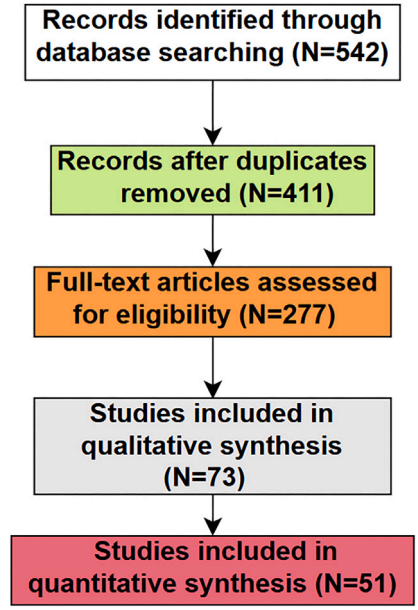

Fig. 2. PRISMA flow diagram illustrating the systematic review process used in this study.

threat source will exploit any possible vulnerability and the consequent impact on a system or organization if that occurs. Organizational damage can result from a threat that exploits a weakness in an organization's assets, as defined by ISO/IEC (Kandasamy et al., 2020). Therefore, the event's probability and its effect on the organization are considered in the risk evaluation. As a result of a cyberattack or exploitation of a breach, an organization's key assets and sensitive information could be exposed and its reputation damaged.

Information security risk includes three main components: asset, threat, and vulnerability. There are precise values assigned to likelihood and impact in the Open-Web Application Security Project (OWASP) testing guide (Khatun et al., 2021), which are used to evaluate the risk, as given by Eq. (1):

$$risk = likelihood \times impact \tag{1}$$

When it comes to defining risk, a variety of methods are proposed, taking into account vulnerabilities, threat, and their occurrence probabilities.

1.1. Review objectives

Our objective in this paper is to review existing solutions and frameworks proposed in the literature to address the problem of risk assessment in IoT environments. This is a hot and timely research as the IoT landscape is continuously changing and evolving; that is new and diverse IoT devices and introduced in the marketplace and integrated with new and existing networks. This makes existing security solutions, and particularly the risk assessment ones, vulnerable or totally obsolete.

The following review objectives are addressed in this survey:

1. Identifying the most important elements of a system that can determine the security risk on that system.
2. Analyzing the interrelationships between the IoT's various components.
3. Provide our critical analysis and recommendations regarding the strengths, weaknesses, and limitations of the proposed solutions and frameworks.

When it comes to zero trust, risk analysis approaches are deemed a good place to start, since IoT device security verification is built on a risk profile. As a result, the study's starting point is an examination of the "IoT device" and its related security risks, which is common to both the Zero-trust paradigm and IoT security verification. The first two objectives necessitate the use of an epistemic method to understand the IoT device and its related security risks. The following lists the key questions that we ask in order to analyze the relationship between security risk and IoT devices.

- For IoT devices, what characteristics might constitute a risk profile?
- To ensure minimal cyber risk, what elements of IoT devices should be taken into account in the design and development of an effective IoT security risk assessment solution?
- How should risk assessment approaches be deployed on IoT devices in order to evaluate the potential risks?

1.2. Review methodology

To conduct an exhaustive review and draw a taxonomy that captures the different risk assessment solutions and frameworks related to the IoT ecosystem, we follow a methodology comprised of several phases.

To ensure a rigorous and systematic selection of relevant literature, we adopted the PRISMA methodology. Fig. 2 illustrates the different phases of our systematic review process, including identification, screening, eligibility, and inclusion of studies related to IoT security risk assessment. This structured approach enhances the reproducibility and transparency of our review.

Fig. 3 presents a structured flowchart illustrating the key phases of the risk assessment methodologies analyzed in this study. The flowchart follows a systematic approach, beginning with the identification of security risks in IoT environments and progressing through various stages, including risk evaluation, classification, and mitigation strategies. This framework helps in understanding how different risk assessment models categorize and address threats based on their impact and likelihood. By visualizing these steps, the figure provides a clear and concise representation of the methodology used to assess security risks in IoT systems.

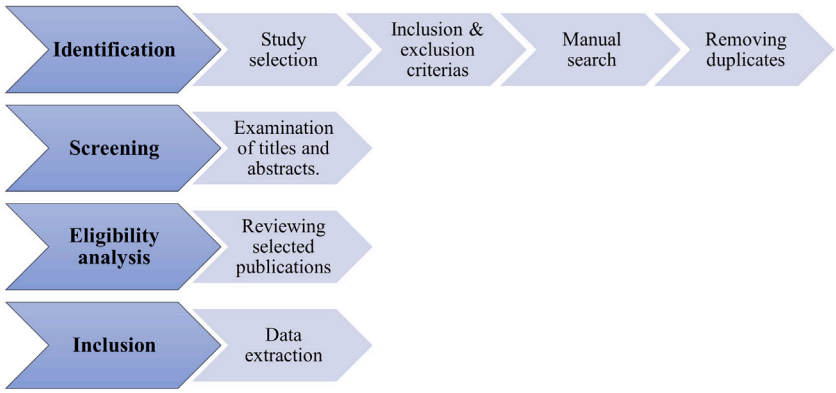

Fig. 3. The phases of SLR utilized in the survey and taxonomy.

As part of the initial phase of our literature review, we identify the most important IoT device security risk indicators. First, we determine the most crucial risk indicators for IoT device security, which led us to conduct a systematic literature review (SLR) that focuses on IoT device security. Then, we use the PRISMA (Page et al., 2021) methodology to establish the SLR, which involves four phases: identification, screening, eligibility analysis, and inclusion. During the identification stage, we select studies, create criteria for inclusion and exclusion, perform manual searches, and remove duplicates. For each research paper, we examine the title and abstract to determine if the study is suitable for consideration. Then, we review the selected research papers in their entirety. Finally, we extract data (e.g., IoT risk assessment) during the inclusion process. Fig. 3 illustrates these phases.

Throughout this literature review, IoT security risk assessment concerns and requirements are examined, as well as the proposed security solutions. First, we illustrate the IoT security vulnerability landscape. Then, we discuss the nature of IoT devices and their deployment circumstances, which might create a greater risk to the security of the entire network, to which they are attached. We conclude with a list of recommended IoT risk assessment solutions.

1.3. Organization of the survey

The rest of the paper is organized as follows: Section 2 explores the IoT landscape and its challenges. Section 3 reviews existing IoT risk assessment frameworks. Section 4 reviews existing IoT risk management frameworks. Section 5 discusses the different risk evaluation methods, perspectives, and methodologies. Section 6 provides a list of widely used IoT risk assessment frameworks. Section 7 discusses the IoT risk assessment gaps and underlines future research directions. Finally, Section 8 concludes the paper.

2. The IoT landscape and challenges

The adoption of "smart" services in digital transformation helps organizations to improve the processes of their operational planning (Sivrikaya et al., 2019). Energy, transportation, agriculture, and even individual homes and communities can all benefit from implementing these "smart" services (López-Vargas et al., 2020; Zhang et al., 2023). The utilization of evolving technologies, such as big data, machine learning (ML), artificial intelligence (AI), cloud computing, and IoT, help developing and deploying such smart services (Andrade and Yoo, 2019). Incorporating these new technologies, on the other hand, has resulted in the emergence of new cybersecurity concerns. Compared to other emerging technologies, IoT inherits specific differences in terms of security (López-Vargas et al., 2020). For instance, one of the intrinsic properties of IoT devices is their lack of sufficient processing capacity and storage, which hinders the implementation and deployment of sophisticated security solutions (Andrade et al., 2020).

An entirely new way of running businesses has been ushered in by the IoT technology, a network of devices and machines that can communicate and collaborate with each other (Lee, 2019). A surge in cyberattacks can be partially attributed to the rapid expansion in IoT devices deployment in sectors, like smart grids, medical monitors, and environmental monitoring. The dynamic nature of the IoT devices makes security management challenging. IoT systems are characterized by their inherently transient nature, a wide range of potential actors, and a scarcity of available resources (Lee, 2020).

As the number of cyberattacks on IoT devices rises, IoT security rules extend and security concerns develop. The IoT security global market is predicted to grow at a compound growth rate of 56% per annum from 2023 to 2028 (Singh, 2023). When it comes to designing an organization's cyber risk management framework, senior management must pay greater attention to IoT-related hazards, according to a recent survey (Lewis, 2016). Furthermore, according to a recent poll, only 35% of respondents stated that they had an IoT security strategy in place, and only 28% had really implemented their strategies. In another poll, it was found that 80% of companies had their IoT devices attacked between 2018 and 2019 (Irdeto, 2019). There are still 26% of the firms, which have not implemented any security protection mechanism. It is clear from these two studies that many IoT devices have security flaws, and that companies must act urgently to correct them.

Existing risk assessment methodologies do not work well with dynamic systems, such as the IoT-enabled ones (Aldmour et al., 2019). Because of their complexity and the numerous attack vectors they expose, medical IoT systems are particularly vulnerable to cyber attacks (Rao et al., 2017; Waqdan et al., 2023a,b, 2025). IoT security can be improved without increasing cyber risks by developing solutions based on standard platforms (Lee, 2020).

Many studies have been conducted in IoT security, as a result of the constrained ability characteristics they have. Establishing security solutions, such as the Zero-trust paradigm for IoT (Xiaojian et al., 2021) and IoT security verification (Kulik et al., 2018), are two examples of security approaches that have been developed. These two approaches have two things in common. The first one is connected to the fact that they build phases or procedures dependent on the IoT device's security level. For example, "Zero-Trust" sets an IoT device's minimal level of security, whereas "Security Verification" requires an evaluation of IoT devices' compliance, based on risk profiles as a first step.

The initial stage of producing "Risk analysis" in these two approaches is generally focused on the evaluation and identification of essential assets, which is related to the second part of this discussion (IoT devices) (Khatun et al., 2021). Several researchers in recent years have explored the security risk analysis approach. They argue that IoT systems have behaviors and characteristics similar to those of IT (Information Technology) systems. According to Kandasamy et al. (2020), the heterogeneity and complexity of IoT systems' technology and data create additional concerns linked to the security risk that

Table 1
Widely utilized risk assessment frameworks.

Frameworks	Area	Strengths	Weaknesses	Assessment type
NIST (Moreira et al., 2021)	Security control	Provides security control guidelines based on risk assessment; widely used in government and industry	Requires collaboration with other standards for compliance; lacks a built-in quantitative risk measurement method	Qualitative
ISO (Proenca et al., 2017)	Compliance with security controls	Defines criteria for evaluating information security threats; widely adopted internationally	Requires continuous updates and coordination to align with evolving standards	Qualitative
MAGERIT (García and Moreta, 2018)	Assets values	Focuses on identifying key assets and mitigating associated threats	Requires significant time to identify and assess the most critical assets	Hybrid (Combines qualitative assessment with some quantitative elements)
TARA (Kieras et al., 2020)	Attack-Based Risk Assessment	Provides structured threat modeling and predictive analysis for high-risk threats	Does not fully quantify the impact of attacks; focuses more on identifying potential attacks rather than complete risk evaluation	Qualitative
FAIR (Fair Institute, 2024)	Threats Classification	Allows for a more precise, numerical risk quantification	Requires extensive data collection and analysis, making implementation time-consuming	Quantitative

cannot simply fit into the existing risk frameworks. Additionally, according to Nurse et al. (2017), risk analysis approaches must take into account the likelihood of limited historical data linked to attacks on IoT devices and the interconnection of IoT with other non-IoT systems when considering dynamic IoT situations.

A few IoT-focused security risk management approaches have been created in light of this (Kandasamy et al., 2020). IoT system elements, such as heterogeneity, several IoT devices, and a layered model, are incorporated into these designs. However, each technique uses various IoT system variables or qualities in comparison to the others, and the selection of specific factors employed is not always justified. IoT security risk can be calculated more accurately using risk analysis in conjunction with the various approaches. Since the IoT security risk analysis methods are not proposed in their formal forms, there is a need for a more accurate and effective IoT security risk analysis approach (Khatun et al., 2021).

3. Iot risk assessment frameworks

In traditional computing systems, risk analysis approaches have been widely utilized to analyze the security risk of computer systems. Table 1 shows some of the widely available and used risk assessment frameworks, along with their benefits and shortcomings.

4. Risk Management Information System (RMIS)

Concerns about the security of Information Systems (IS) have grown over the past two decades, whether in the public or commercial sectors. As a result, security Risk Management (RM) has become a critical component of every company's risk management strategy. Since security threats can be overwhelming, it is hard to address them all because (1) any technology security solution has a monetary cost, and (2) enterprises have limited resources. As a result, businesses require reassurance that the solutions they implement will yield a substantial Return on Investment (ROI). Comparing a solution's expenses against the risk of not employing it, such as a business interruption due to a successful security attack, is used to make this determination (Affia et al., 2023). Security Risk Management (SRM) plays a critical role in aligning companies business plans with their IT strategy (Dubois et al., 2010).

There are literally more than a hundred of SRM standards, guides, and methodologies available for IS, all geared towards professionals in the security field. Identification of sensitive assets, development of their risk assessment, and support of the security objectives are among the primary components of these standards and guides. Losses that could be caused by security issues can be minimized by employing these guidelines and standards. Nevertheless, in IoT, these solutions need more adapted to enable modeling, since they do not consider the dynamism and scalability of IoT systems. Instead, they tend to use standard languages and impromptu diagrams to describe their approaches, such as in NIST and ISO. There is a lack of the utilization of conceptual modeling methodologies, sophisticated abstraction mechanisms, automation, and visualizations (Nurse et al., 2017). In Fig. 4, we illustrated examples of risk management approaches, IoT vulnerabilities, and attacks, which will be discussed in more detail in the following sections.

4.1. Risk framing

In the coming years, advances in AI will provide significant governance and risk challenges for societies. With the rise of "the tethered self", or to borrow Turkle's phrase, pervasive network connectivity, we are already witnessing these challenges (Turkle, 2006). To deal with a more or less continual connection to the digital world, we perceive the user's self as compromised in this world. The border separating the online digital world from the offline world is becoming increasingly blurred. To be fair, customers can choose whether or not to participate in the digital world at this time, but it is becoming increasingly difficult, uncertain, and even impossible to do. As IoT is becoming more and more omnipresent, we believe that citizens will gradually lose their ability to navigate between the digital and physical worlds. This will eventually lead to a situation where the self is effectively directed through the digital world by AI Assistants (AIAs) (Cunneen and Mullins, 2019). Data monetarization has already begun and created a considerable impetus for this move through the new technologies, such as IoT and AIAs.

However, AI assistants in IoT environments introduce new security and reliability concerns. AI models deployed in IoT networks are vulnerable to adversarial attacks, where malicious actors manipulate input data to deceive AI-driven decision-making processes. For instance, AI-powered threat detection systems can be tricked into misclassifying malware, allowing attacks to bypass security mechanisms. Additionally, AI-based IoT systems must be robust against data poisoning attacks, where attackers introduce misleading data to corrupt the model's learning process. Since AI often makes autonomous security decisions, its stability is crucial—flaws in AI-based risk assessment models may lead to incorrect threat prioritization, increasing the risk of breaches.

Risk management is becoming more difficult in online contexts because of the particular risks involved. Online activities are prevailing conceptions of human autonomy and autonomy based on full disclosure and informed agreement. According to Cunneen and Mullins (2019), through articulating the risks connected with the issues affecting the

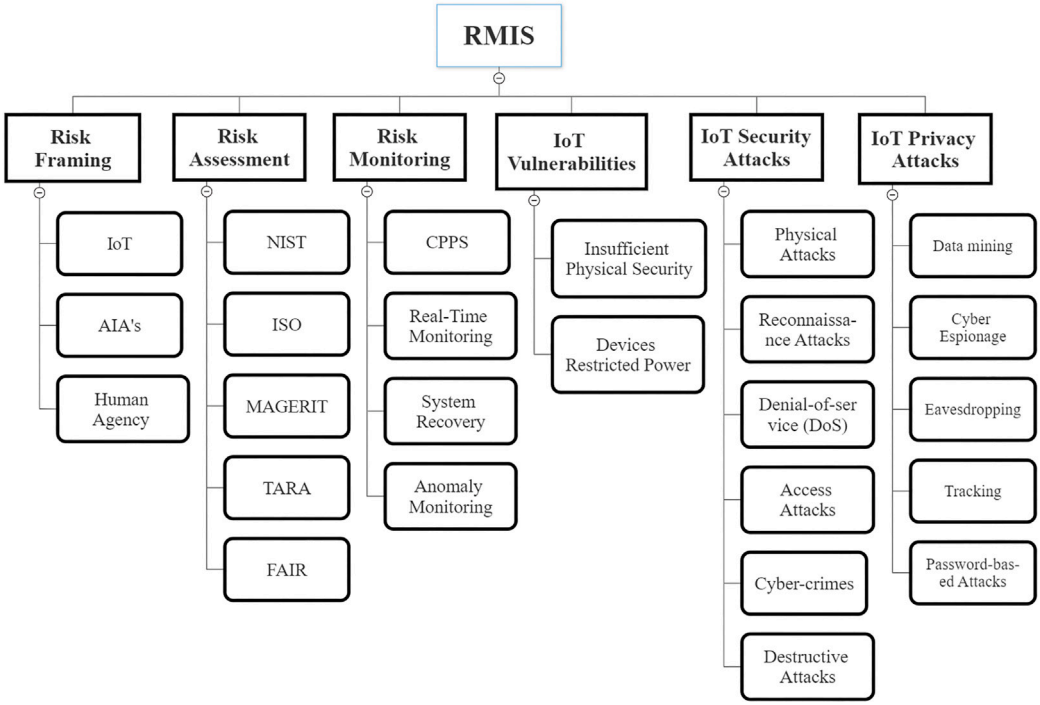

Fig. 4. Risk management information systems.

three phrases of "always-on", "the ubiquity of IoT", and "the appearance of AI assistants", researchers can provide better clarity to the numerous actors confronted with building systems of risk governance. The contextual relevance of the three phrases of growing connectivity brings attention to a connectivity landscape and regulatory regime that is becoming increasingly complex. Contextualization is important for illuminating the shifting environment of inter-actor relationships and threats.

4.2. Risk assessment

Some risk assessment techniques are based on the potential harm to key assets, while others are based on threats and the degree to which they are feasible (Nurse et al., 2017). The traditional method of risk assessment is predicated on a periodic review, assuming that the systems will not undergo a major change in a short period of time (Nurse et al., 2017). IoT devices attached to a network have a cascaded effect on risk likelihood and repercussions on current risk assessment approaches, which fail to take them into account (Radanliev et al., 2018). The risk is calculated as follows:

$$Risk = Likelihood \times Consequences \tag{2}$$

In risk management, there are a variety of risk assessment frameworks. Assets of an organization should be viewed not only as valuable but also as attack platforms (Nurse et al., 2018). It is inevitable that the number of IoT devices will rise because they are already lowering costs by evaluating and optimizing the data they collect (Waqdan et al., 2023a). Assessing generic cyber hazards is the goal of these six frameworks; NIST, ISO, MAGERIT, TARA, and FAIR. The latter is the only one that uses qualitative data. Customers should be aware of the dangers and vulnerabilities associated with IoT devices during risk assessment. Besides, security specialists must work together to identify threats, avoid attacks, respond to incidents, and embed security measures at the early design stages of IoT devices. A robust incident-response strategy must also be deployed by both companies and users in the event of a malfunction, with clearly defined actions and owners.

IoT-related features, like the heterogeneity of devices and networks, vulnerabilities and attacks on communication and physical layers, and the application domains of IoT systems are taken into account in proposed risk assessment approaches. It is not always clear or documented in these proposed solutions how these features were selected or how they were weighted for the global risk evaluation. In order to establish the values of the components utilized in the risk assessment process, techniques such as MAGERIT, OCTAVE, and TARA (Sardjono and Cholik, 2018) benefit from extensive documentation. These publications provide detailed methodologies, formulas, and tools. There is a need for new approaches or new proposals that focus on IoT in order to bridge the gap in standard risk analysis methodologies, which do not cover all aspects of IoT systems connected to risk.

Quantitative approaches focus on assessing cyber risk, which restricts the scope of the studies. In Khosravi-Farmad and Ghaemi-Bafghi (2020), the authors modeled the network security risk management using Bayesian Decision Network (BDN). Risk assessment, risk validation, and monitoring are all components of the framework and must be carried out precisely to improve the network's security. Risk reduction techniques and their impact on vulnerabilities are only few examples of what BDN can represent when it comes to managing security risks. With modified Bayesian inference methods, a cost–benefit analysis of risk reduction is performed (Khosravi-Farmad and Ghaemi-Bafghi, 2020). According to their findings, the framework's correct risk assessment and suitable risk reduction assist increase network security.

The exact characteristics of ISO 27005 are expanded upon by AVARCIBER, which is another risk assessment framework (Rea-Guaman et al., 2020). The AVARCIBER framework begins with an initial risk assessment, followed by an inventory of assets, a review of threats to those assets, a determination of the damage level for each vulnerability-asset (dimension) tuple, and an evaluation of the risks. Compared to ISO 27005, the overall process is not different. There are, however, more in-depth activities and instructions available. Case studies were conducted to verify the framework's implementation. When it was discovered that the NIST Cybersecurity Framework lacked a financial mechanism that could be used to justify cybersecurity projects, a cost–benefit analysis was included (Gordon et al., 2020). Using cost–benefit analysis, the study reveals how firms can select the most appropriate NIST implementation tier level and its relationship to the firm's appropriate amount of cybersecurity spending. A lack of information on how

to divide funds among numerous cybersecurity initiatives is a major shortcoming of this study.

4.3. Risk monitoring

The technology used to monitor and evaluate traditional security risks is unable to adapt to Cyber–Physical Power Systems (CPPS), in terms of evaluation criteria, real-time monitoring, and technological reliability (Li et al., 2019). As enterprise network technology has advanced and Internet applications have become more popular, a single computer system is no longer sufficient to handle the demands of today's omnipresent network applications. Because an increasing number of devices are being connected to the network, network anomalies are becoming increasingly commonplace. As a result, researchers' primary goal has always been to increase system reliability. System recovery and anomaly monitoring are the two main processing methods for handling system exceptions. Based on the system's history and current status, anomaly monitoring is implemented. When a risk assessment system is able to detect abnormalities, it can prevent them and take action to recover its functionality from any potential attacks as quickly as possible (Li et al., 2019).

The concept of anomaly monitoring is based on the fact that anomalous behaviors differ from typical user activities, and that difference can be represented qualitatively and quantitatively. Network logs are used to train a monitoring model and to detect regular user activities in order to recognize anomalous behavior (Kandhro et al., 2023). Because it does not require a description of an attack feature set, this approach can also be used to keep tabs on previously undiscovered intrusions. Data mining and other technologies are commonly used in anomaly monitoring in order to obtain the best results by learning from data logs. Furthermore, integrating adaptive anomaly detection (AAD) techniques is crucial to identifying evolving cyber threats in CPS environments.

Moriano et al. conducted a systematic literature review on AAD, emphasizing the need for model adaptation to counter sophisticated attacks. They introduced a taxonomy covering attack types, CPS applications, learning paradigms, data management, and algorithms, providing a comprehensive overview of current AAD research (Moriano et al., 2024). Similarly, deep learning-based anomaly detection (DLAD) methods have been explored to address the increasing complexity of CPS. Luo et al. reviewed DLAD methods, proposing a taxonomy based on anomaly types, detection strategies, implementation, and evaluation metrics. They discussed limitations and open problems in DLAD methods, offering insights into selecting appropriate models for specific CPS applications (Luo et al., 2021). Furthermore, ensemble Kalman filter (EnKF) approaches have been applied for anomaly detection in CPS. Karimipour and Leung proposed an anomaly detection framework using EnKF with a relaxation-based solution, addressing computational burdens and demonstrating effectiveness in detecting false data injection attacks in large-scale power systems (Karimipour and Leung, 2020).

4.4. IoT vulnerabilities and attacks

IoT applications and systems are rapidly growing in acceptance and use. The development of technology and its capacity to connect everything is the driving force behind this phenomenon. The IoT is enabling an ever-evolving network architecture that makes use of the Internet as a communication and data-transmission medium in an effort to bring the real and virtual worlds closer to each other (Elijah et al., 2018). The self-configuring IoT architecture seamlessly merges the real and virtual worlds into a single big-data network through the use of communication protocols. It can also be seen as a networked collection of computers, mechanical and electrical machines, objects, animals, and/or people, all of which have a common ability to communicate and exchange data via an established network without the need for direct human intervention. The IoT is a maturing revolution that will touch millions of people around the world by enabling machines to communicate with one another and operate independently of human control. The ultimate goal of IoT has always been the use of any existing smart network to allow seamless, real-time, and omnipresent connectivity of devices (Porkodi and Bhuvaneswari, 2014).

Since Kevin Ashton coined the term "Internet of Things" in 1999, this all-encompassing network of connections is now an integral part of our daily lives, with notable applications in many fields, such as military, medicine, industry, energy, and farming. Our world is becoming increasingly intelligent thanks to the Internet and AI, which also reduce the need for human intervention and make things easier for us to utilize.

A vital principle of an IoT system is the exchange of data between nodes, facilitated by state-of-the-art technologies. Examples of these technologies include Radio Frequency Identification (RFID) and Wireless Sensor Networks (WSN) and utilizing sensing devices endowed with strong deliberation abilities and intelligent algorithms. Successful deployment of IoT systems relies on integrating internet-connected telecommunication interfaces in devices, like actuators and sensors, which are equipped with data storage and processing modules. Despite the convenience they provide, these new standard has some security and privacy flaws that must be addressed before they can be deployed (Gubbi et al., 2013). For instance, RFID, initially introduced in 1945, is essential for the IoT. It is a technological advancement that uses radio waves to allow machines to identify objects, store metadata about them, and manipulate a single target (Amendola et al., 2014). Conventionally, RFID systems include both readers and tags (Da Xu et al., 2014). Tags, which consist of a microchip and a receiving wire, can be attached to anything in order to provide an indelible identity. An object can be identified and categorized on its own with the use of radio waves and a reader/tag pair via radio communication. In RFID, other technologies can be used, including WSN, Electronic Product Codes (EPCs), bar codes, ZigBee, and Bluetooth. These technologies are considered the most popular and convenient IoT-enabling technologies operating on low-power devices.

The current number of IoT devices connected is around 25 billion, but this number is expected to explode to around 60 billion by 2025. The IoT is a recursive phenomenon, as it gathers standards and gives a machine augmented intelligence that allows it to analyze, behave, and act in response to given circumstances. Sensors are used to establish a link and sense the user over a network. By building an enhanced intelligence for it, the device's ability to do an action, create a communication, aggregate data, and analyze it all at once is what makes it interconnected to IoT. Every step of this IoT process is crucial to the next, and the whole cycle repeats until completion (Balaji et al., 2019).

Security issues in the IoT cannot be fixed unless all the system assets that make up the IoT system are identified. The entire asset inventory, including all IoT devices, components, and services, must be understood. The physical components of the IoT system include the backbone of the system (e.g., machinery, buildings, etc.) (Vermesan et al., 2022), services, software, and data generated by the facilities (Kizza et al., 2013).

Multiple IoT characteristics enable device-based security vulnerabilities. An example of these vulnerabilities is insufficient physical security, which may cause a side-channel attack that could reveal the encryption keys of an IoT device. Attackers can exploit this vulnerability by measuring the relationships between its physical and internal readings. Another example of IoT device-based vulnerability is the limited energy of these devices with no practical way to recharge them automatically. Attackers can take advantage of this vulnerability to drain the IoT devices' batteries, causing them to be out of service and unable to accomplish their planned processing tasks. Numerous attacks exploited this vulnerability, such as sinkhole attacks, battery-draining attacks, and jamming attacks (Neshenko et al., 2019).

4.4.1. Vulnerability

A vulnerability is a flaw in a system or its design that could be exploited by an attacker to gain control of the system, steal information, or even cause a denial of service (Bertino et al., 2010; Pipkin, 2003). Different components of IoT systems may have security flaws. Defects can reside anywhere in the system, from the hardware and software to the policies and procedures, and even the users themselves (Vermesan et al., 2022).

The two primary pillars of an IoT system are its hardware and its software, and both of them might have design flaws. Even if a vulnerability in the hardware is discovered, it would be difficult to patch it due to issues with hardware compatibility and interoperability, as well as the time and effort required to implement the patch. Various types of software, applications, including operating systems, and controls like communication protocols and device drivers all have the potential to include bugs that could compromise the entire system. Software complexity and human factors are two of the main causes of flawed software design. Many flaws in technology can be traced back to human carelessness. Starting an IoT project without a strategy, misunderstandings between users and developers, a lack of skills, resources, and knowledge, and a failure to manage and control the system are all outcomes of a lack of requirement comprehension (Vermesan et al., 2022). Examples of some of the IoT vulnerabilities can be found in the Common Vulnerabilities Scoring System (CVSS) database, which contains information about vulnerabilities in software and hardware in IoT systems, along with their respective CVSS scores. While (CVSS) provides a widely used framework for evaluating IoT vulnerabilities, it is important to acknowledge certain limitations. One key concern is that CVSS scores may not always accurately reflect the real-world probability of a successful attack. The scoring system relies on predefined metrics, which may not account for evolving threat landscapes, contextual factors, or attacker capabilities. Additionally, the lack of real-time adaptability in CVSS means that scores assigned at a given point in time may become outdated as new exploit techniques emerge. As a result, security practitioners often supplement CVSS scores with additional risk assessment methodologies, such as threat intelligence feeds, adversary emulation, and historical attack data analysis, to obtain a more comprehensive understanding of an IoT system's security posture.

4.4.2. Attacks

An attack is a deliberate attempt to cause damage to, or disruption of, a system by exploiting its vulnerabilities. Attackers conduct attacks in order to accomplish objectives, whether for monetary gain or personal gratification. Attack cost is the measurement of an attacker's level of effort, taking into account their skill, resources, and determination to succeed (Pipkin, 2003). Criminals who pose a risk to the Internet are called "attack actors" (Schneier, 2015). The culprits might be anyone from criminals and hackers or even governmental organizations (Vermesan et al., 2022).

Attacks can be either active, in which the attacker actively seeks out sensitive information by monitoring unencrypted network traffic, or disrupts the normal functions of the targeted system. It can also be passive, in which the attacker monitors unprotected network communications in order to recover weakly encrypted traffic and obtain authentication information, or even more localized, in which the attacker exploits a vulnerable system or individual. Types of frequent cyber attacks include:

1. Physical attacks: With this type of attack, physical parts of the system are modified. Most IoT devices operate in open spaces, where they are vulnerable to physical attacks because of their unattended and dispersed nature (Sun and Du, 2018).
2. Reconnaissance attacks: They refer to unauthorized mapping of services, systems, or vulnerabilities. Reconnaissance attacks can take many forms, including port scanning (Ansari et al., 2003), packet sniffing (De Vivo et al., 1999), analyzing traffic, and querying IP addresses.
3. Denial-of-service (DoS): An attempt is made in this type of attack to deny access to a network or computer resource. Resource enervation attacks can affect a wide variety of IoT devices due to their limited storage and processing power (Pakmehr et al., 2024; Salim et al., 2020).
4. Access attacks: When this happens, people who should not be able to access certain networks or devices become able to do so. The first kind of access assault occurs when an intruder actually handles the hardware of a system. The second is IP-connected device remote access.
5. Attacks on privacy: As more and more data becomes accessible through remote access techniques, protecting users' privacy in the IoT has become a greater challenge (Aqeel et al., 2022). Threats to users' privacy that are most frequently encountered include:
    - Data mining: Information that is not normally found in a database can be mined by an attacker using data mining techniques (Wang et al., 2021).
    - Cyber espionage: Hacking and malicious software are used in cyber espionage to eavesdrop on or steal sensitive data from private companies, government agencies, or individuals (Mhara et al., 2024).
    - Eavesdropping: Attackers listen in on a private conversation without permission (Naumann and Hogben, 2008).
    - Tracking: The device's identifier can be used to follow its owner around UID (Unique Identifier). When a user is trying to maintain their anonymity online, tracking their whereabouts can be used to positively identify them (Damghani et al., 2019).
    - Password-based attacks: Attackers try to guess a user's password in order to get access to his account. There are two main and popular methods for discovering acceptable passwords: the "dictionary attack", which tries every word or a combination of words from a dictionary or lists of widely used words, and the "brute force attack", which uses cracking tools to try every possible combination (Renuka et al., 2019).
6. Cyber crimes: There are several forms of cybercrime, including intellectual property theft, grand theft, identity theft, and fraud. They make use of smart products, that are connected to the Internet, convenient, and accessible (Vermesan et al., 2022; Wilson, 2008).
7. Destructive attacks: Large-scale disturbance and loss of life and property are caused by using space. Terrorism and the act of retribution are two types of harmful attacks.

Over the past three decades, the field of risk analysis has seen a rapid interest in public attention. Risk analysis has also established itself as a comprehensive and successful approach that supplements and enhances the management of nearly all facets of our lives. Decision-making in the medical, environmental, and physical infrastructure sectors is all aided by risk analysis. Moreover, the amazing development of theory, methodology, and practical instruments is owed to the widespread adoption of risk analysis by several disciplines and its deployment by industry and government agencies in decision-making (Haimes, 2009) .

A hazard is any unsafe state or possible cause of harm or damage, whereas risk is the probability that a valued person or object may be negatively affected by the hazard (Woodruff, 2005; Reniers et al., 2005). Risk is also described as the measure of the probability and impact of unfavorable events or the impact of a hazard in the face of uncertainty (Haimes, 2009; Høj and Kröger, 2002). Humans, machines, and the dynamic interaction between them are all parts of a complex human-machine system that can be captured in a system model. When

considering the potential for system failure, or accidents more generally, it is crucial to consider the purpose of a system model. Different incidents might be attributed to different causes, such as faulty components ("error mechanisms") or simply bad luck. There have been a lot of cliched explanations and forecasting methods proposed throughout the years in an effort to shed light on the causes of accidents and prevent them from happening in the future (Hollnagel et al., 2006).

Furthermore, risk assessment is a methodical approach for assessing the impact, incidence, and consequences of human activities on systems with risky characteristics, making it an indispensable approach for a company's safety strategy. This is mostly due to the fact that there is a wide variety of risk analysis methods, and thus choosing the proper one is largely a matter of taste (Reniers et al., 2005; Rouvroye and van den Bliek, 2002).

4.4.3. Cyberattacks on IoT systems

With the widespread adoption of the IoT, new security challenges have emerged, making these devices attractive targets for cybercriminals. Unlike conventional IT systems, many IoT devices operate with limited computational power and lack robust security protocols, increasing their vulnerability to attacks. This section provides an overview of some of the most impactful cyberattacks on IoT systems and references the relevant literature to offer a deeper understanding of their implications.

- Notable Cyberattacks on IoT Systems:

1. Mirai Botnet (2016)
   The Mirai botnet is one of the most well-documented IoT-based cyberattacks. It exploited IoT devices with default usernames and passwords to launch massive Distributed Denial-of-Service (DDoS) attacks, taking down major websites and internet services. This attack demonstrated how poorly secured IoT devices could be leveraged for large-scale cyber threats (Antonakakis et al., 2017).
2. Stuxnet (2010)
   Although Stuxnet primarily targeted industrial control systems (ICS), it remains a significant example of how IoT-related vulnerabilities can be exploited for cyber warfare. Stuxnet's sophisticated design allowed it to manipulate programmable logic controllers (PLCs), showcasing the risks associated with IoT devices in critical infrastructure (Falliere et al., 2011).
3. BrickerBot (2017)
   BrickerBot was a malware strain that targeted unsecured IoT devices with the intention of permanently disabling them. Unlike traditional botnets that recruit devices for malicious activities, BrickerBot rendered devices unusable, demonstrating the potential for IoT "permanent denial-of-service" (PDoS) attacks (Antonakakis et al., 2017).

- Common Attack Vectors on IoT Systems:

1. Botnet-Based Attacks
   IoT botnets, such as Mirai, infect devices with weak credentials or outdated firmware to launch large-scale attacks. These attacks can disrupt services and even cripple critical infrastructure (Jakkani et al., 2023; Singh et al., 2024).
2. Man-in-the-Middle (MitM) Attacks
   MitM attacks occur when an attacker intercepts communication between IoT devices and servers. Many IoT sensors transmit unencrypted data, making them susceptible to eavesdropping and data manipulation (Cekerevac et al., 2017; Fereidouni et al., 2025).
3. Firmware Attacks
   IoT firmware often lacks regular updates, making it vulnerable to backdoors and supply chain attacks. Malware can be injected into the firmware, compromising the entire network (Bettayeb et al., 2019; Feng et al., 2022; Bakhshi et al., 2024).
4. Jamming and Signal Interference Attacks
   Wireless IoT devices, particularly those using Wi-Fi, Bluetooth, or Zigbee, are susceptible to jamming attacks. Attackers can flood the communication channel with noise, preventing legitimate data transmission and causing service disruption (Ambika, 2020; Zahra et al., 2023).

The security landscape of IoT systems is evolving rapidly, and cybercriminals continue to find new ways to exploit vulnerabilities. Learning from past attacks, such as Mirai, Stuxnet, and BrickerBot, can help researchers and organizations strengthen IoT security mechanisms. Future research should focus on improving authentication methods, secure firmware updates, and real-time intrusion detection to mitigate emerging threats.

5. Risk analysis and evaluation methods

5.1. Evaluation methods

Our evaluation of the scientific literature showed a wealth of published technical work on safety and risk analysis referring to many various sectors, including engineering, chemistry, medicine, agronomy, biology, etc. Planning, designing, developing, integrating, prototyping, and building physical infrastructure; quality control, reliability, and maintenance are all topics covered in this research work. Our research review also revealed that there are primarily three types of risk analysis and assessment (RAA) methods: qualitative, quantitative, and hybrid (or semi-quantitative) techniques.

Qualitative analysis techniques rely on expert knowledge from fields like engineering and safety management in addition to statistical estimation methods. When applied to real-world data on workplace accidents, quantitative techniques consider risk as a numeric score amenable to mathematical expressions. Risk, when approached in line with quantitative approaches and employing real-world accident data, can be seen as a quantity that can be stated by mathematical numbers. Because most of its foundations were improvised, hybrid approaches are challenging to implement widely.

5.1.1. Quantitative methods

Quantitative methods attempt to assign monetary values to the various assets identified as being at risk. The true value of the assets is calculated by factoring in the replacement cost, the loss of productivity, the damage to the company's brand reputation, and any other values that stand in for the assets themselves, whether they are direct or indirect.

There are only a handful of guidelines that must be adhered to when using a quantitative approach to risk analysis. In the first phase, the company's assets are cataloged and analyzed to calculate the possible loss in the event of an attack. Estimates of how much it would cost to replace a given asset in the event of its total or partial loss. In the event of its loss or failure, any asset can affect one of the three fundamental tenets of security—integrity, confidentiality, and accessibility. One of the characteristics of data is its secrecy, which means that it cannot be read by any third parties without permission. To ensure that no unauthorized parties have made any changes to the data in a way that is either detectable or undetectable by legitimate users, the data must possess the property of integrity. Principals' (people and machines) access to resources is safeguarded by the availability of the assets (Jerman-Blažič et al., 2008).

Once this asset analysis is completed, the Expected Annual Loss (EAL) can be determined by adding the dollar amounts of all the assets in question and then multiplying them by the probabilities of each risk they might face.

Determining what actions should be taken and their associated ROI is the final stage of the quantitative analysis. In this phase, we determine which risks pose the greatest potential for AEL and which preventative actions can best mitigate that risk. For instance, the following factors are considered:

Table 2
Qualitative vs. Quantitative methods in risk assessment.

Criteria	Quantitative methods	Qualitative methods
Risk assessment approach	Uses numerical data to quantify risk impact and likelihood.	Uses expert judgment and categorical scales to assess risk.
Suitability for IoT	Often struggles with real-time assessment due to dynamic device behavior.	More adaptable for evolving IoT threats but may lack precision.
Threat intelligence	Can integrate machine learning models for anomaly detection and threat prediction.	Relies on historical knowledge, making it harder to detect emerging IoT-specific attacks.
Device heterogeneity	Difficult to apply uniformly due to diverse device architectures and communication protocols.	Can account for different device types but may generalize risk levels.
Scalability	Computationally intensive for large-scale IoT networks.	More scalable but may oversimplify security risks.
Firmware & OTA update risks	Can model potential vulnerabilities in firmware updates but requires complex probabilistic modeling.	Easier to assess risk but lacks quantitative validation for update security.
Threat propagation & Cascading risks	Captures how attacks spread across connected IoT devices.	May not fully capture how vulnerabilities in one device affect others.
Best use case	Works well in controlled environments where detailed threat modeling is possible.	Best for preliminary risk assessment in dynamic IoT environments.

- The dangers that will be lessened as a result of the measure's implementation.
- The average annual loss from each risk.
- The effectiveness of risk.
- ROI: Return On Investment.

Maximizing the ROI and minimizing the AEL are two factors that should be considered when deciding which security control measures to use. Maximizing the efficiency gains, or reducing the cost of measures, increases the ROI.

5.1.2. Qualitative methods

Most often, small businesses opt for a more qualitative method. This approach does not factor in statistical values when assessing risk. The value of the prospective loss is being recorded instead of using relative values. A risk's frequency of occurrence and its impact are, respectively, referred to as common and significant. Information of this sort and categorization is of the utmost importance; vital, important, critical, and general. A 3-2-1 strategy can be deployed to help a system to continue working even in the presence of failures, by doing the following tasks: Burtescu (2005)

- Estimating the lost if a vulnerability is exploited by a threat and giving points for different loss scenarios.
- Determining the disaster expenses.
- Estimating the likeliness of a catastrophic event occurrence.
- Creating a record of the disasters' effects.
- Developing a *Matrix for Analyzing Qualitative Risks* that identifies threats, their possibility of happening, and their impact.

Table 2 illustrates a comparison between qualitative and quantitative methods.

5.1.3. Semi-quantitative methods

In contrast to qualitative methods, the semi-quantitative ones do not provide a deeper comprehension of the issue. Decisions can be made as confidently and consistently as if they are made by an expert, thanks to the employment of semi-quantitative procedures, which can be used without specialized knowledge (Shook and Grantham, 1993; Droppo et al., 1993). Most of these tools were created so that government agencies can carry out their regulatory functions, especially in risk assessment and evaluation related to areas of contaminated lands. When compared to their quantitative counterparts, semi-quantitative methods require less computing time to complete an analysis (Mwiya, 2003).

Semi-quantitative methods, on the other hand, use "scoring approaches" to integrate less potential uncertainty than qualitative methods. Scoring is one method of expressing the outcomes of an evaluation alongside one's level of expertise and relevant background information. It is important to remember that even when common phrases are employed, there is still room for debate because of differences in observation and interpretation, which make them somehow subjective.

5.2. Evaluation perspectives

Potential risk can be assessed from three angles: business, asset, and service. The primary goal of this section is to determine the total amount of available resources for the company. Besides, determine which level of available resources poses the greatest threat to the business. In contrast to the business-driven perspective, which focuses on risks to operational procedures, the asset-driven perspective analyses assets and the risks they present at the asset level. On the other hand, the service-driven perspective takes into account threats to services, as an input to the risk assessment process.

5.2.1. Asset-driven strategy

The most frequent approach to evaluating risk is the asset-driven perspective. In this view, assets are cataloged and appraised before the dangers they pose are estimated. An Information Security Risk Assessment (ISRA) (Shameli-Sendi et al., 2016) methodology must identify the organization's significant information assets and carefully measure the risks to which they are exposed in order to attain the required level of information security (Shedden et al., 2011). Each asset's potential dangers and weaknesses are cataloged in an asset-driven strategy, and then risk scenarios are developed.

Large and medium-sized businesses have thousands of assets, when multiplied by the typical number of potential dangers associated with each item of data, results in a massive list of risk scenarios that must be regularly examined and updated. The fundamental flaw of the asset-driven perspective is that it makes assessing the risk time-consuming and sometimes inaccurate. Because of their widespread use, most market-ready solutions are developed from an asset-driven vantage point, which has the primary benefit of being intuitively understandable.

5.2.2. Service-driven strategy

Risks are recognized and evaluated in terms of their effect on operations from a service-driven viewpoint. From this vantage point, the organization's most vital offerings are singled out, followed by their

most popular service bundles. A service-driven perspective, in contrast to an asset-driven one, concentrates on the services themselves rather than on the assets that support them. Compared to the number of assets in an organization, the number of services is typically far smaller, making a service-driven strategy more convenient to administer and manage.

5.2.3. Business-driven strategy

Methods for evaluating potential threats to information security that are "business-driven" are founded on strategic objectives, while the operational procedures are designed to achieve them (Khanmohammadi and Houmb, 2010). Instead of assigning monetary worth to physical assets, this business-driven view prioritizes the value of the activities that contribute directly to the organizational objectives. A company's business operations can be more easily estimated and analyzed than its information assets. The business-driven viewpoint specifies and analyzes the weak elements and their potential dangers in business operations. With this lens, it may be less difficult to explain the risk assessment conclusions to upper management and win their backing and support, as they will have a clear bearing on the organization's objectives and aims.

5.3. Resource valuation

Estimating the worth of available resources is a crucial part of any risk analysis (i.e., services, assets, business). Fig. 5 shows that the number of choices in C3 (resource valuation) is proportional to the number of choices made in C2 (perspective). For instance, if we take an asset-driven approach to risk management and isolate threats at the portfolio level, we will have to assign a monetary value to each asset. The service value or the business value will also be essential when taking a service- or business-driven approach to the issue at hands.

5.3.1. Interdependency between assets and its impact on risk assessment

One critical factor in resource valuation that must be considered in CPS and IoT environments is the interdependency between assets. In highly interconnected systems, the failure or compromise of one asset can have cascading effects on other dependent assets, significantly impacting overall system security and performance. These interdependencies introduce complex risk propagation dynamics, where a vulnerability in a less critical component can escalate into a system-wide security breach if exploited strategically (Kavallieratos et al., 2021). From a resource allocation perspective, interdependencies necessitate prioritizing security investments based on not only the individual importance of an asset but also its role within the system. For example, cyber risk-aware resource allocation models consider these relationships by assigning higher protection to assets that serve as critical nodes in the network (Chui et al., 2023). Similarly, game-theoretic models have been employed to optimize cybersecurity investments by predicting attack paths and minimizing potential system disruptions (Hyder and Govindarasu, 2020). Understanding asset interdependencies also enhances risk assessment accuracy, as traditional independent risk evaluation methods may underestimate the actual risk posed by interconnected vulnerabilities. Graph-based modeling techniques have been proposed to quantify interdependencies and simulate attack scenarios to predict potential cascading failures (Ghaleb and Azzedin, 2021). By incorporating interdependency-aware risk models, IoT and CPS operators can make more strategic security investments and implement proactive mitigation measures.

Connections can exist both horizontally and vertically among the aforementioned resource types (see Fig. 6).

5.3.2. Vertical view

As shown in Fig. 6, the vertical view is a bottom-up approach that takes into account the relative importance of the various resources at various organizational levels.

(i) The asset independently of its contribution to the other levels is denoted by V(I), and stands for Vertical (Independent).
(ii) The asset contribution to the organization's services is denoted by V(AS), and stands for Vertical (Asset to Service).
(iii) The asset contribution to the organization's business processes is denoted by V(AB), and stands for Vertical (Asset to Business).
(iv) V(ASB) stands for the asset contribution to the organization (i.e., service and business).

Two choices exist, V(I) and V(SB), if we elect to conduct a service-oriented risk assessment of potential security threats (Service-driven). Given that the business level concludes the bottom-up view, the vertical approach makes little sense here. The vertical perspective might affect the outcome of a resource valuation. For instance, consider two identical routers installed in different parts of a corporation (e.g., Finance and R&D). In the V(I) view, the values of these two routers are identical, but in the V(AB) view, the value of the router that is more important to the company's operations is higher (Eom et al., 2007).

Though the vertical view offers reasonable estimations of resource value, the selected approach makes it challenging to analyze all of those dependencies when estimating the resource value.

5.3.3. Horizontal view

The horizontal view refers to the interdependence between resources on the same level, whereas the vertical view refers to the relationships between resources on separate levels. From a horizontal perspective, resource valuation is typically divided into two types of models: dependent and independent. In Fig. 6, we see two different types of horizontal models labeled H(I) for Horizontal (Independent) and H(D) for Horizontal (Dependent). Taking the router example from the previous section, in the H(I) model, each router is evaluated separately from its importance to the other resources at the same level. On the other hand, in the H(D) model, the evaluation depends on the resources at their level. It should be noted that resources depend on each other as well as their values.

5.4. Risk valuation methodologies

The last stage of risk management is measuring the level of risk. There are two distinct types of quantification methodologies: propagated and non-propagated.

5.4.1. Non-propagated methodology

In this methodology, risk on a resource is assessed irrespective of its influence on the other resources. From the business-driven perspective (Khanmohammadi and Houmb, 2010), this means a conscious decision is made to separate risks from company operations. Then, multiplying up the value of the business process, the effect of the vulnerability, and the effect of the threat. This is a quick and easy way to assess the risk level. Thus, risk is quantified independently from how far its effects might be propagated from the damaged business resources.

5.4.2. Propagated methodology

It is common for the effects of an attack on one resource to spread out to the other resources (Jahnke et al., 2007; Kheir et al., 2010; Mahmoud et al., 2011). Propagated risk is quantified in this model by traversing the dependency graph between resources. It is possible, for instance, that a vulnerable node could spread the associated risk to other nodes in the network. There are two distinct types of spread when a resource is compromised: forward and backward (Shameli-Sendi et al., 2015, 2017, 2018). The term "backward impact" refers

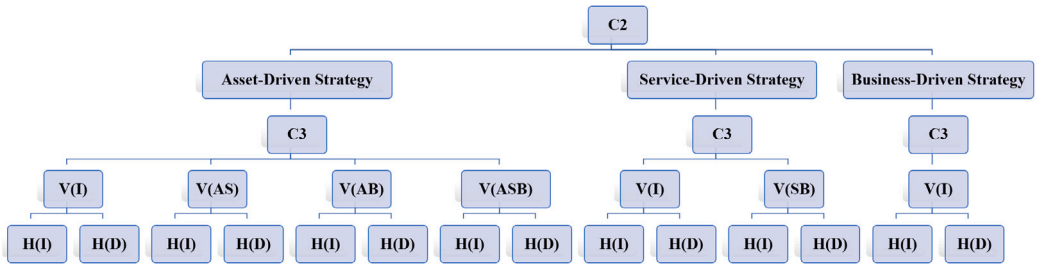

Fig. 5. Valuation of resources and their connections to the different perspectives (asset, service, and business) (Shameli-Sendi et al., 2016).

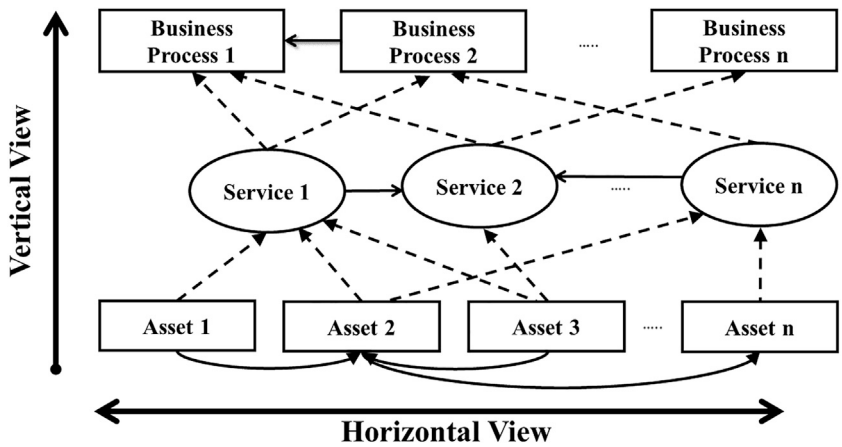

Fig. 6. The vertical and horizontal views used in resource valuation. The former depicts the relationships between resources on different levels, while the latter shows the relationships between resources on the same level (Shameli-Sendi et al., 2016).

to the ripple effect on all services that directly or indirectly rely on the compromised resource. On the other hand, forward impact describes how a compromised resource can have a domino effect on all of its dependent resources, regardless of the permission type between them.

The reverse effect of a DoS assault is on availability, while that of a User to Remote (U2R) to Root to Local (R2L) attack is spread across the board for the CIA. Let us suppose that an Apache server needs the MySQL service in order to function properly. Apache will transmit incorrect data to the website if an attacker tries to conduct a U2R attack on the MySQL service.

If an attacker manages to get root access to a resource, he can then use forward impact propagation to inflict damage on any resource that relies on the compromised one, according to the permissions between the two resources. For example, if an attacker gains full access, he might alter any and all the CIA parameters (through a U2R or R2L attack) or just resource availability (if the attack type is DoS). No matter what kind of attack is carried out, however, read-only permissions will only impair the availability.

Propagated risk measurement's primary benefit is its ability to foretell the potential damage cost that may be incurred by the attack in the subsequent phase. However, the computation requires precise information regarding the type of attack, the degree of dependency between resources in terms of integrity, confidentiality, and availability, and the type of predefined access authorization between resources.

6. IoT risk assessment

Shameli-Sendi et al. outlined the fundamental elements of a risk assessment that should be embedded in a comprehensive security program (Shameli-Sendi et al., 2016). They introduced a new risk assessment taxonomy to aid businesses in comparing and selecting the appropriate approach among the existing concepts and methods of risk assessment. Quantitative risk assessment models, such as the one described by Kavallieratos et al. (2021), enable to model the security posture of an organization, analyze its security measures, and reveal its exposure to potential threats. They also validated the proposed models in an industrial situation and provided a full explanation of the formulations.

All the organization's assets must be analyzed for potential dangers, which are prioritized and estimated as part of the risk assessment procedure. Due to its importance, as a stepping stone towards handling risks, risk assessment is fundamental to the risk management process as a whole. The risk assessment method takes into account a variety of factors, including the likelihood of an assault and the severity of its effects.

Variables specific to each risk assessment technique are worth considering. That is, the methodology and the approach employed to quantify the risk are two crucial characteristics that are relevant to the valuation of risk.

6.1. IoT risk assessment frameworks

As explained earlier, cyber-risk assessment can be performed using either qualitative or quantitative methods. Popular risk assessment frameworks include ISO/IEC, NIST, TARA, and OCTAVE.

6.1.1. NIST

It is a framework that is comprehensively documented and offers recommendations for implementing risk management and assessment (Krumay et al., 2018). However, the framework does not include a model. NIST lacks a quantitative method for assessing the potential consequences of the IoT system, instead favoring a more qualitative approach. The NIST framework is available as an option for organizations to use during disaster and recovery planning. However, NIST takes IoT risk management into account in an IoT version of its standards and guidelines. Potential issues with IoT devices and risk concerns in establishing data and device security are documented in NIST IR 8228 (Hussein et al., 2021) and NIST IR 8259 (Fagan et al., 2020).

6.1.2. OCTAVE

It is an Operationally Critical Threat, Asset, and Vulnerability Evaluation framework. It is a framework for qualitative risk assessment with eight steps or procedures, which are: (1) establishing criteria for measuring risk; (2) creating asset profiles; (3) locating asset containers; (4) pinpointing areas of concern; (5) cataloging threat schemes; (6) acknowledging risks; (7) analyzing risks; and (8) taking preventative measures.

Some systems use a hybrid approach, combining qualitative and quantitative techniques. An example of such approaches is what the GSMA global organization has developed as a methodology for assessing the security of IoT projects, with OCTAVE serving as the foundation platform (Kandasamy et al., 2020). The GSMA hybrid approach was designed to be integrated into the conventional view of the supply chain, as it is based on a systematic methodology.

6.1.3. ISO

ISO (International Standards Organization) is advocating, among other activities, for the standardization of cyber risk (Kandasamy et al., 2020). When it comes to information security, the ISO/IEC 27001 standard is the gold standard because it develops and maintains risk criteria, identifies the owners of risks, and conducts risk analysis based on those criteria. The risks associated with IoT applications can be mitigated, and their potential advantages can be maximized with the help of the reference architecture provided by ISO/IEC 30141. The standards for protecting the privacy and security of IoT devices are outlined in ISO/IEC 27030.

6.1.4. TARA

TARA stands for Threat Assessment & Remediation Analysis (Wynn et al., 2011). It is a framework that aids in system recovery, but does nothing to mitigate the severity of cyber risks. For the most important risks, TARA provides a predictive framework. TARA has three primary benefits. It reduces the number of possible threats to a more manageable number. It helps the company better convey risks and suggestions and enhances the accuracy of risk and control assessments. It can improve results, lessen the time spent on risk analysis, and lead to wiser choices. TARA does not emphasize on vulnerability mitigation or risk quantification. TARA is typically used in conjunction with the NIST framework, and the NIST's guidelines on the IoT are relevant here as well.

6.2. Analysis of IoT risk assessment frameworks

Understanding the specifics of IoT systems and why conventional methods of risk evaluation are inadequate is crucial (Nurse et al., 2017). There are limitations to periodic assessments in IoT systems because of the rapid pace at which IoT systems are evolving as a result of the interoperability of IoT devices. It is essential to perform regular verification on the IoT infrastructure. The IoT ecosystem introduces new threats and vulnerabilities due to interconnected assets to the Internet.

Traditional risk assessment methods focus on the organization's assets as if they were values. However, in IoT systems, the devices themselves may be the target of attacks. Failure can also occur during evaluation of the procedures by which devices are bound, i.e., the connections that allow these devices to couple and operate in an IoT system. Therefore, the standard procedure for assessing cyber risk needs to be adapted for use with IoT devices in light of the aforementioned considerations.

IoT deployment differs from conventional IT in significant ways, due to the nature of its networking paradigm. As a result of the wide variety of connectivity models and devices present in the IoT ecosystem, the CIA trinity may not always be supported. Automatic, data encryption, access controls, and authentication, software patching, or upgrades are all examples of common security technology. IoT devices, for all their adaptability and interoperability, raise a number of potential entry points for cybercriminals. Once again, the requirement to safeguard a network is exacerbated by the proliferation of attack vectors brought about by upgrades to device firmware, protocols, and applications. The IoT risk assessment process should be built to be very comprehensive for these reasons.

In IoT and Cyber–Physical Systems (CPS), security defense mechanisms must account for heterogeneous losses associated with different assets, as their criticality and vulnerability levels vary significantly. Transitioning from network-centric to asset-centric security models enables tailored protection strategies that align with each asset's specific requirements, thereby improving overall security resilience. Risk assessment frameworks that consider factors such as hardware, networking, operating systems, software, data, and human elements facilitate the development of adaptive security defenses in heterogeneous IoT environments (Luo et al., 2024). Various studies have explored how asset-specific risk evaluation enhances security strategies. For instance, machine learning-based anomaly detection and asset-centric security frameworks have been proposed to dynamically assess threats based on asset importance and vulnerability levels (Huang et al., 2025). Similarly, game-theoretic and probabilistic models have been used to optimize resource allocation for defending high-value assets in CPS infrastructures (Tushar et al., 2023). Implementing security reference architectures further guides the identification and protection of critical assets, enhancing the overall resilience of IoT and CPS infrastructures (Weisman et al., 2025). Such approaches improve security decision-making by aligning risk mitigation strategies with the expected impact on different assets, thereby ensuring robust defense mechanisms.

6.3. Comparison of risk assessment frameworks

The areas of focus, strengths, weaknesses, and other characteristics of each risk assessment framework are summarized in Table 3. In addition, the latter describes the assessment methodology, the industries in which they are utilized, and the published criteria. It may be deduced from Table 3 that not all four risk assessment frameworks cover the CIA principles. Researching the risk assessment procedure used in business, finance, and healthcare is essential to complement a thorough examination of these frameworks.

7. Discussion

Risk assessment in IoT and CPS environments is a critical challenge due to the dynamic nature of threats, the heterogeneity of devices, and the complexity of interdependencies between assets. This paper aimed to analyze and categorize existing risk assessment frameworks while identifying gaps and proposing future research directions. Our key findings indicate that while various qualitative, quantitative, and hybrid methodologies exist, most current frameworks struggle with adaptability, real-time risk evaluation, and standardized risk metrics. By examining prominent risk assessment frameworks, we identified their strengths and limitations in addressing these challenges.

A number of methodologies for assessing information security risks have been developed over the past decade, but many businesses still struggle to find one that works for them (Shamala et al., 2013). In this review, we proposed a taxonomy for four categories of information security risk assessment methodologies: Appraisal, Resource Valuation, Perspective, and Risk Measurement. Qualitative, quantitative, and mixed approaches to evaluating potential threats to information systems exist (Shameli-Sendi et al., 2016). Companies make their decision based on their values and tolerance for uncertainty.

Table 3
Comparison of risk assessment frameworks (Kandasamy et al., 2020).

Framework	Owner	Focus area of IoT	Weakness	Strengths	Industrial application	Risk assessment method of IoT	CIA coverage	IoT standard published
NIST (Moreira et al., 2021)	NIST	• Standard Technology. • Publications. • Partnerships. • Government adoption. • Market intelligence.	• There is documentation for a framework, but no corresponding automated tool. • Risk cannot be measured.	• Appropriate framework for controlling cyber threats. • Great for post-disaster recovery.	• Manufacturing. • Healthcare. • Insurance. • Government. • Financial. • Security/Risk consultancy firms.	Compliance (guidelines and standards with documentation).	Yes	Yes
OCTAVE (Alberts et al., 2003)	Octave Allegro	• Organizational information resources.	• There is currently no quantifiable means of estimating restoration.	• To investigate and categorize the effects of recovery, a standardized questionnaire has been developed.	• Smart homes designed for startups with a tight budget.	Qualitative method.	Yes	No
TARA (Kieras et al., 2020)	Intel	• Analysis of vulnerabilities of attacks and the potential for repairing damage.	• Absence of risk effect quantification.	• Predictive structure for the most significant risks.	• Industry. • Healthcare. • Finance. • Insurance.	Qualitative method.	No	Yes
ISO (Proenca et al., 2017)	ISO	• Universally accepted risk criteria.	• Need for mandatory adherence to international standards.	• Support of international cooperation and sharing of information on cyber risks.	• Corporate. • Small business. • Private. • Government.	Compliance (guidelines and standards with documentation).	Yes	Yes

7.1. Challenges in IoT risk assessment

Weaknesses, issues, and restrictions in the current quantitative and qualitative information security risk assessment methodologies have been outlined (Kandasamy et al., 2020). The purpose of quantitative risk assessment is to use statistical methods to quantitatively evaluate information assets, safeguards, risks, and impacts (Lo and Chen, 2012). Valuing information assets, identifying risks, and estimating control costs all need significant effort. One of the most influential quantitative methodologies is the ALE, as previously discussed. The EF cannot be determined with any accuracy using the information provided in ALE. When it comes to calculating EF, the majority of quantitative risk assessment methods do not offer a standardized technique and instead leave that up to the practitioners (Asosheh et al., 2009).

Experts use their discretion (which is inherently subjective) to place monetary values on intangibles, like information assets, risks, protections, and impacts in qualitative risk management appraisals (Wang and Zeng, 2010). The outcomes of a qualitative appraisal are highly dependent on the security specialists who do the risk analysis, which undermines the usefulness of the appraisal to decision-makers due to the absence of adequate and measurable details (Wang and Zeng, 2010). Some models attempt to eliminate the drawbacks of the two distinct valuations by combining their greatest aspects into a third one, a hybrid valuation.

7.2. Limitations of existing risk assessment frameworks

There is no "one-size-fits-all" appraisal; even if one looks perfect for one circumstance, budget, or industry, it may not work for others. Organizations must spend a lot of money on research and development of information security solutions to ensure the safety of their sensitive data and assets. To justify these expenditures, management must be convinced that they will obtain a positive return. Many aspects must be considered when deciding whether a quantitative, qualitative, or hybrid appraisal approach is most suitable.

Risks can be looked at from three different angles: those focused on assets, those focused on services, and those focused on the business as a whole. Asset-driven models predominate in risk assessment. Unfortunately, there are restrictions in the asset-driven risk assessment methodology. First, there is typically a large quantity of assets, which makes an accurate value of those assets challenging. Second, there is a lot of effort required to accurately estimate the monetary value of assets, the frequency of threats, and the cost of controls.

Table 4
Comparative evaluation of risk assessment frameworks.

Framework	Efficiency	Accuracy	Applicability
NIST	High	Moderate	Broad (Industry & Government)
ISO	Moderate	High	International Standards Compliance
OCTAVE	Moderate	High	Organizational Risk Assessment
TARA	High	Moderate	Threat Analysis & Response

7.3. Comparative evaluation of risk assessment frameworks

To provide a clearer comparison of the various risk assessment frameworks, Table 4 presents an evaluation of their efficiency, accuracy, and applicability based on key factors. This comparison highlights how different frameworks perform in real-world applications, showcasing their strengths and weaknesses in relation to efficiency, accuracy, and suitability for various contexts.

7.4. Future research directions

When assessing the value of a company's information assets, several factors must be considered (Wheeler, 2011): a broad description of the asset, its function and features, its classification, its importance to the company, its relevant rules, and targeted users. Information assets, such as firewalls, switches, or databases, can be difficult to value because of the many factors that must be considered. Third, it is difficult to spot major risks since the risks' outputs are so close to each other.

Finally, the close proximity of dangers makes the risk reduction phase of this paradigm inefficient. In contrast, the shortcomings of the asset-driven paradigm are attempted to be remedied by the business-driven and service-driven alternatives. In both of these views, services and business processes are the primary targets of resource extraction and risk management. This is because risk assessment can gain a more complete picture of how a business or service process affects income.

Measuring the risk assessment can be done using two main methodologies: Propagated and Non-Propagated. When it comes to evaluating potential dangers, the non-propagated methods are by far the most popular. Actually, the risk effect is computed without taking into account any potential security dependency linkages between nodes or any conceptions of risk transmission. Companies who are not concerned with pinpoint precision in their ISRA models, even when dealing with a huge number of risks and resources, will find this model to be both deployable and versatile. The primary issue with this methodology is that the risk effect value does not account for any prospective losses. Risk transmission among interdependent resources is the subject of a small number of published papers (Mahmoud et al., 2011). With the help of the propagation model, we can predict precisely which nodes in the network will be compromised. This model can then be used to select effective security measures.

8. Conclusion

In this paper, we provided an in-depth survey and taxonomy of the IoT risk domain by analyzing relevant theories, industry solutions, risk frameworks, and risk vectors. We took a close look at the cyber-security risk assessment frameworks that hold promise for IoT devices. In-depth analyses of four risk models are presented, viz., OCTAVE, NIST, ISO, and TARA. We outlined the benefits and drawbacks of each framework, as well as their respective areas of application and issues regarding IoT risk. The quantitative approach is highlighted by providing a summary of the IoT risk assessment and a risk ranking system tailored for IoT environments.

CRediT authorship contribution statement

Mofareh Waqdan: Writing – review & editing, Writing – original draft, Visualization, Validation, Supervision, Software, Resources, Project administration, Methodology, Investigation, Funding acquisition, Formal analysis, Data curation, Conceptualization. **Habib Louafi:** Writing – review & editing, Visualization, Validation, Supervision, Project administration. **Malek Mouhoub:** Writing – review & editing, Visualization, Validation, Supervision.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data availability

No data was used for the research described in the article.

References

Affia, A.-a.O., Nolte, A., Matulevičius, R., 2023. IoT security risk management: A framework and teaching approach. Inform. Educ..

Alberts, C., Dorofee, A., Stevens, J., Woody, C., 2003. Introduction to the OCTAVE Approach. Carnegie Mellon University, Pittsburgh, PA, pp. 72–74.

Aldmour, R., Burnap, P., Lakoju, M., 2019. Risk assessment methods for converged IoT and SCADA systems: Review and recommendations.

Ambika, N., 2020. Tackling jamming attacks in IoT. Internet Things (IoT) Concepts Appl. 153–165.

Amendola, S., Lodato, R., Manzari, S., Occhiuzzi, C., Marrocco, G., 2014. RFID technology for IoT-based personal healthcare in smart spaces. IEEE Internet Things J. 1 (2), 144–152.

Andrade, R.O., Yoo, S.G., 2019. A comprehensive study of the use of LoRa in the development of smart cities. Appl. Sci. 9 (22), 4753.

Andrade, R.O., Yoo, S.G., Tello-Oquendo, L., Ortiz-Garcés, I., 2020. A comprehensive study of the IoT cybersecurity in smart cities. IEEE Access 8, 228922–228941.

Ansari, S., Rajeev, S., Chandrashekar, H., 2003. Packet sniffing: a brief introduction. IEEE Potentials 21 (5), 17–19.

Antonakakis, M., April, T., Bailey, M., Bernhard, M., Bursztein, E., Cochran, J., Durumeric, Z., Halderman, J.A., Invernizzi, L., Kallitsis, M., et al., 2017. Understanding the mirai botnet. In: 26th USENIX Security Symposium (USENIX Security 17). pp. 1093–1110.

Aqeel, M., Ali, F., Iqbal, M.W., Rana, T.A., Arif, M., Auwul, M.R., 2022. A review of security and privacy concerns in the internet of things (IoT). J. Sens. 2022 (1), 5724168.

Asosheh, A., Dehmoubed, B., Khani, A., 2009. A new quantitative approach for information security risk assessment. In: 2009 2nd IEEE International Conference on Computer Science and Information Technology. IEEE, pp. 222–227.

Bakhshi, T., Ghita, B., Kuzminykh, I., 2024. A review of IoT firmware vulnerabilities and auditing techniques. Sensors 24 (2), 708.

Balaji, S., Nathani, K., Santhakumar, R., 2019. IoT technology, applications and challenges: a contemporary survey. Wirel. Pers. Commun. 108 (1), 363–388.

Bertino, E., Martino, L., Paci, F., Squicciarini, A., 2010. Security for Web Services and Service-Oriented Architectures, vol. 1, Springer.

Bettayeb, M., Nasir, Q., Talib, M.A., 2019. Firmware update attacks and security for IoT devices: Survey. In: Proceedings of the ArabWIC 6th Annual International Conference Research Track. pp. 1–6.

Burtescu, E., 2005. Securitatea Datelor Firmei. Independența Economică.

Cekerevac, Z., Dvorak, Z., Prigoda, L., Cekerevac, P., 2017. Internet of things and the man-in-the-middle attacks–security and economic risks. MEST J. 5 (2), 15–25.

Chui, K.T., Gupta, B.B., Liu, J., Arya, V., Nedjah, N., Almomani, A., Chaurasia, P., 2023. A survey of internet of things and cyber-physical systems: Standards, algorithms, applications, security, challenges, and future directions. Information 14 (7), 388.

Cunneen, M., Mullins, M., 2019. Framing risk, The new phenomenon of data surveillance and data monetisation; from an 'Always-On'culture to 'Always-On'artificial intelligence assistants. Hybrid Worlds 65.

Cybersecurity Ventures, 2022. 2022 Cybercrime Report: Global Damage Projections. Tech. Rep., Cybersecurity Ventures, Accessed 13 March 2025.

Da Xu, L., He, W., Li, S., 2014. Internet of things in industries: A survey. IEEE Trans. Ind. Inform. 10 (4), 2233–2243.

Damghani, H., Damghani, L., Hosseinian, H., Sharifi, R., 2019. Classification of attacks on IoT. In: 4th International Conference on Combinatorics, Cryptography, Computer Science and Computation. pp. 245–255.

De Vivo, M., Carrasco, E., Isern, G., De Vivo, G.O., 1999. A review of port scanning techniques. ACM SIGCOMM Comput. Commun. Rev. 29 (2), 41–48.

Droppo, Jr., J., Buck, J., Strenge, D., Hoopes, B., 1993. Risk computation for environmental restoration activities. J. Hazard. Mater. 35 (3), 341–352.

Dubois, É., Heymans, P., Mayer, N., Matulevičius, R., 2010. A systematic approach to define the domain of information system security risk management. In: Intentional Perspectives on Information Systems Engineering. Springer, pp. 289–306.

Elijah, O., Rahman, T.A., Orikumhi, I., Leow, C.Y., Hindia, M.N., 2018. An overview of Internet of Things (IoT) and data analytics in agriculture: Benefits and challenges. IEEE Internet Things J. 5 (5), 3758–3773.

Eom, J.-H., Park, S.-H., Han, Y.-J., Chung, T.-M., 2007. Risk assessment method based on business process-oriented asset evaluation for information system security. In: International Conference on Computational Science. Springer, pp. 1024–1031.

Fagan, M., Fagan, M., Megas, K.N., Scarfone, K., Smith, M., 2020. IoT Device Cybersecurity Capability Core Baseline. US Department of Commerce, National Institute of Standards and Technology ....

Fair Institute, 2024. What is a cyber value-at-risk model?. URL https://www.fairinstitute.org/blog/what-is-a-cyber-value-at-risk-model. (Accessed 29 August 2024).

Falliere, N., Murchu, L.O., Chien, E., et al., 2011. W32. stuxnet dossier. White Pap. Symantec Corp. Secur. Response 5 (6), 29.

Feng, X., Zhu, X., Han, Q.-L., Zhou, W., Wen, S., Xiang, Y., 2022. Detecting vulnerability on IoT device firmware: A survey. IEEE/ CAA J. Autom. Sin. 10 (1), 25–41.

Fereidouni, H., Fadeitcheva, O., Zalai, M., 2025. IoT and man-in-the-middle attacks. Secur. Priv. 8 (2), e70016.

García, F.Y.H., Moreta, L.M.L., 2018. Maturity model for the risk analysis of information assets based on methodologies MAGERIT, OCTAVE y MEHARI; focused on shipping companies. In: 2018 7th International Conference on Software Process Improvement. CIMPS, IEEE, pp. 29–39.

Ghaleb, M., Azzedin, F., 2021. Towards scalable and efficient architecture for modeling trust in iot environments. Sensors 21 (9), 2986.

Gordon, L.A., Loeb, M.P., Zhou, L., 2020. Integrating cost–benefit analysis into the NIST cybersecurity framework via the Gordon–Loeb Model. J. Cybersecur. 6 (1), tyaa005.

Gubbi, J., Buyya, R., Marusic, S., Palaniswami, M., 2013. Internet of Things (IoT): A vision, architectural elements, and future directions. Future Gener. Comput. Syst. 29 (7), 1645–1660.

Haimes, Y., 2009. Risk Modelling, Assessment, and Management. John Willey & Son, edn.

Høj, N.P., Kröger, W., 2002. Risk analyses of transportation on road and railway from a European perspective. Saf. Sci. 1 (40), 337–357.

Hollnagel, E., Woods, D.D., Leveson, N., 2006. Resilience Engineering: Concepts and Precepts. Ashgate Publishing, Ltd..

Huang, J., Lai, X., Yang, F., Zhang, N., Niyato, D., Jiang, W., 2025. Ellipsoid-based learning for robust resource allocation with differentiated QoS in massive internet of vehicles networks. IEEE Trans. Veh. Technol..

Hussein, M., Trautman, L.J., Ngamassi, L., Molesky, M.J., 2021. Climate, cyber risk, and the promise of the internet of things (IoT). Available At SSRN.
Hyder, B., Govindarasu, M., 2020. Optimization of cybersecurity investment strategies in the smart grid using game-theory. In: 2020 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference. ISGT, IEEE, pp. 1–5.
Irdeto, 2019. New 2019 global survey: Iot-focused cyberattacks are the new normal.
Jahnke, M., Thul, C., Martini, P., 2007. Graph based metrics for intrusion response measures in computer networks. In: 32nd IEEE Conference on Local Computer Networks (LCN 2007). IEEE, pp. 1035–1042.
Jakkani, A.K., Reddy, P., Jhurani, J., 2023. Design of a novel deep learning methodology for IoT botnet based attack detection. Int. J. Recent. Innov. Trends Comput. Commun. 11 (9), 4922–4927.
Jerman-Blažič, B., et al., 2008. An economic modelling approach to information security risk management. Int. J. Inf. Manage. 28 (5), 413–422.
Kandasamy, K., Srinivas, S., Achuthan, K., Rangan, V.P., 2020. IoT cyber risk: A holistic analysis of cyber risk assessment frameworks, risk vectors, and risk ranking process. EURASIP J. Inf. Secur. 2020 (1), 1–18.
Kandhro, I.A., Alanazi, S.M., Ali, F., Kehar, A., Fatima, K., Uddin, M., Karuppayah, S., 2023. Detection of real-time malicious intrusions and attacks in IoT empowered cybersecurity infrastructures. IEEE Access 11, 9136–9148.
Karimipour, H., Leung, H., 2020. Relaxation-based anomaly detection in cyber-physical systems using ensemble kalman filter. IET Cyber- Phys. Syst.: Theory Appl. 5 (1), 49–58.
Kavallieratos, G., Spathoulas, G., Katsikas, S., 2021. Cyber risk propagation and optimal selection of cybersecurity controls for complex cyberphysical systems. Sensors 21 (5), 1691.
Khanmohammadi, K., Houmb, S.H., 2010. Business process-based information security risk assessment. In: 2010 Fourth International Conference on Network and System Security. IEEE, pp. 199–206.
Khatun, M., Glaß, M., Jung, R., 2021. An approach of scenario-based threat analysis and risk assessment over-the-air updates for an autonomous vehicle. In: 2021 7th International Conference on Automation, Robotics and Applications. ICARA, IEEE, pp. 122–127.
Kheir, N., Cuppens-Boulahia, N., Cuppens, F., Debar, H., 2010. A service dependency model for cost-sensitive intrusion response. In: European Symposium on Research in Computer Security. Springer, pp. 626–642.
Khosravi-Farmad, M., Ghaemi-Bafghi, A., 2020. Bayesian decision network-based security risk management framework. J. Netw. Syst. Manage. 28 (4), 1794–1819.
Kieras, T., Farooq, M.J., Zhu, Q., 2020. RIoTs: Risk analysis of IoT supply chain threats. In: 2020 IEEE 6th World Forum on Internet of Things (WF-IoT). IEEE, pp. 1–6.
Kizza, J.M., Kizza, W., Wheeler, 2013. Guide to Computer Network Security. Springer.
Krumay, B., Bernroider, E.W., Walser, R., 2018. Evaluation of cybersecurity management controls and metrics of critical infrastructures: A literature review considering the nist cybersecurity framework. In: Nordic Conference on Secure IT Systems. Springer, pp. 369–384.
Kulik, T., Tran-Jørgensen, P.W., Boudjadar, J., Schultz, C., 2018. A framework for threat-driven cyber security verification of iot systems. In: 2018 IEEE International Conference on Software Testing, Verification and Validation Workshops. ICSTW, IEEE, pp. 89–97.
Kumar, S., Tiwari, P., Zymbler, M., 2019. Internet of Things is a revolutionary approach for future technology enhancement: a review. J. Big Data 6 (1), 1–21.
Lee, I., 2019. The Internet of Things for enterprises: An ecosystem, architecture, and IoT service business model. Internet Things 7, 100078.
Lee, I., 2020. Internet of Things (IoT) cybersecurity: Literature review and IoT cyber risk management. Futur. Internet 12 (9), 157.
Lewis, J.A., 2016. Managing Risk for the Internet of Things. JSTOR.
Li, Q., Meng, S., Zhang, S., Wu, M., Zhang, J., Ahvanooey, M.T., Aslam, M.S., 2019. Safety risk monitoring of cyber-physical power systems based on ensemble learning algorithm. IEEE Access 7, 24788–24805.
Lo, C.-C., Chen, W.-J., 2012. A hybrid information security risk assessment procedure considering interdependences between controls. Expert Syst. Appl. 39 (1), 247–257.
López-Vargas, A., Fuentes, M., Vivar, M., 2020. Challenges and opportunities of the internet of things for global development to achieve the united nations sustainable development goals. IEEE Access 8, 37202–37213.
Luo, L., Morales-Gonzalez, C., Wang, S., Ling, Z., Fu, X., 2024. Unified view of IoT and CPS security and privacy. In: 2024 International Conference on Computing, Networking and Communications. ICNC, IEEE, pp. 495–499.
Luo, Y., Xiao, Y., Cheng, L., Peng, G., Yao, D., 2021. Deep learning-based anomaly detection in cyber-physical systems: Progress and opportunities. ACM Comput. Surv. 54 (5), 1–36.
Mahmoud, M.S.B., Larrieu, N., Pirovano, A., 2011. A risk propagation based quantitative assessment methodology for network security-aeronautical network case study. In: 2011 Conference on Network and Information Systems Security. IEEE, pp. 1–9.
Mhara, M.A.A., Abdulrahman, A.A., Baroud, A.A., 2024. Cyber attacks and threats: Study of the types of cyber attacks: Hacking, viruses, targeted attacks, and electronic espionage. Int. J. Electr. Eng. Sustain. 38–47.
Moreira, F.R., Da Silva Filho, D.A., Nze, G.D.A., de Sousa Júnior, R.T., Nunes, R.R., 2021. Evaluating the performance of NIST's framework cybersecurity controls through a constructivist multicriteria methodology. IEEE Access 9, 129605–129618.
Moriano, P., Hespeler, S.C., Li, M., Mahbub, M., 2024. Adaptive anomaly detection for identifying attacks in cyber-physical systems: A systematic literature review. arXiv preprint arXiv:2411.14278.
Mwiya, S., 2003. Development of a Knowledge-Based System Methodology for Designing Solid Waste Disposal Sites in Arid and Semiarid Environments (Ph.D. thesis). University of Portsmouth.
Naumann, I., Hogben, G., 2008. Privacy features of European eID card specifications. Netw. Secur. 2008 (8), 9–13.
Neshenko, N., Bou-Harb, E., Crichigno, J., Kaddoum, G., Ghani, N., 2019. Demystifying IoT security: An exhaustive survey on IoT vulnerabilities and a first empirical look on Internet-scale IoT exploitations. IEEE Commun. Surv. Tutor. 21 (3), 2702–2733.
Nurse, J.R., Creese, S., De Roure, D., 2017. Security risk assessment in internet of things systems. IT Prof. 19 (5), 20–26.
Nurse, J.R., Radanliev, P., Creese, S., De Roure, D., 2018. If you can't understand it, you can't properly assess it! The reality of assessing security risks in Internet of Things systems.
Page, M.J., McKenzie, J.E., Bossuyt, P.M., Boutron, I., Hoffmann, T.C., Mulrow, C.D., Shamseer, L., Tetzlaff, J.M., Akl, E.A., Brennan, S.E., et al., 2021. The PRISMA 2020 statement: an updated guideline for reporting systematic reviews. Int. J. Surg. 88, 105906.
Pakmehr, A., Aßmuth, A., Taheri, N., Ghaffari, A., 2024. Ddos attack detection techniques in IoT networks: a survey. Clust. Comput. 27 (10), 14637–14668.
Pipkin, D.L., 2003. Halting the Hacker: A Practical Guide to Computer Security. Prentice Hall Professional.
Porkodi, R., Bhuvaneswari, V., 2014. The internet of things (IoT) applications and communication enabling technology standards: An overview. In: 2014 International Conference on Intelligent Computing Applications. IEEE, pp. 324–329.
Proenca, D., Estevens, J., Vieira, R., Borbinha, J., 2017. Risk management: a maturity model based on ISO 31000. In: 2017 IEEE 19th Conference on Business Informatics. CBI, 1, IEEE, pp. 99–108.
Radanliev, P., De Roure, D., Cannady, S., Montalvo, R.M., Nicolescu, R., Huth, M., 2018. Economic impact of IoT cyber risk-analysing past and present to predict the future developments in IoT risk analysis and IoT cyber insurance.
Rao, A., Carreón, N., Lysecky, R., Rozenblit, J., 2017. Probabilistic threat detection for risk management in cyber-physical medical systems. IEEE Softw. 35 (1), 38–43.
Ray, P.P., 2018. A survey on Internet of Things architectures. J. King Saud Univ.-Comput. Inf. Sci. 30 (3), 291–319.
Rea-Guaman, A.M., Mejía, J., San Feliu, T., Calvo-Manzano, J.A., 2020. AVARCIBER: a framework for assessing cybersecurity risks. Clust. Comput. 23 (3), 1827–1843.
Reniers, G.L., Dullaert, W., Ale, B., Soudan, K., 2005. Developing an external domino accident prevention framework: Hazwim. J. Loss Prev. Process. Ind. 18 (3), 127–138.
Renuka, K., Kumari, S., Zhao, D., Li, L., 2019. Design of a secure password-based authentication scheme for M2M networks in IoT enabled cyber-physical systems. IEEe Access 7, 51014–51027.
Rouvroye, J.L., van den Bliek, E.G., 2002. Comparing safety analysis techniques. Reliab. Eng. Syst. Saf. 75 (3), 289–294.
Salim, M.M., Rathore, S., Park, J.H., 2020. Distributed denial of service attacks and its defenses in IoT: a survey. J. Supercomput. 76, 5320–5363.
Sardjono, W., Cholik, M.I., 2018. Information systems risk analysis using octave allegro method based at deutsche bank. In: 2018 International Conference on Information Management and Technology (ICIMTech). IEEE, pp. 38–42.
Schneier, B., 2015. Secrets and Lies: Digital Security in a Networked World. John Wiley & Sons.
Shamala, P., Ahmad, R., Yusoff, M., 2013. A conceptual framework of info structure for information security risk assessment (ISRA). J. Inf. Secur. Appl. 18 (1), 45–52.
Shameli-Sendi, A., Aghababaei-Barzegar, R., Cheriet, M., 2016. Taxonomy of information security risk assessment (ISRA). Comput. Secur. 57, 14–30.
Shameli-Sendi, A., Louafi, H., Cheriet, M., 2017. Payless monitoring service for tenants in cloud with traffic and energy-aware function deployment. In: 2017 IEEE International Conference on Cloud Computing Technology and Science (CloudCom). pp. 247–254. http://dx.doi.org/10.1109/CloudCom.2017.22.
Shameli-Sendi, A., Louafi, H., He, W., Cheriet, M., 2015. A defense-centric model for multi-step attack damage cost evaluation. In: 2015 3rd International Conference on Future Internet of Things and Cloud. pp. 145–149. http://dx.doi.org/10.1109/FiCloud.2015.39.
Shameli-Sendi, A., Louafi, H., He, W., Cheriet, M., 2018. Dynamic optimal countermeasure selection for intrusion response system. IEEE Trans. Dependable Secur. Comput. 15 (5), 755–770. http://dx.doi.org/10.1109/TDSC.2016.2615622.
Shedden, P., Scheepers, R., Smith, W., Ahmad, A., 2011. Incorporating a knowledge perspective into security risk assessments. Vine.
Shook, G., Grantham, C., 1993. A decision analysis technique for ranking sources of groundwater pollution. J. Environ. Manag. 37 (3), 201–206.
Sikder, A.K., Petracca, G., Aksu, H., Jaeger, T., Uluagac, A.S., 2018. A survey on sensor-based threats to Internet-of-Things (IoT) devices and applications. ArXiv abs/1802.02041.
Singh, S., 2023. IoT security market worth 59.2 billion USD by 2028. Available at https://www.marketsandmarkets.com/PressReleases/iot-security.asp.
Singh, N.J., Hoque, N., Singh, K.R., Bhattacharyya, D.K., 2024. Botnet-based IoT network traffic analysis using deep learning. Secur. Priv. 7 (2), e355.

Sivrikaya, F., Ben-Sassi, N., Dang, X.-T., Görür, O.C., Kuster, C., 2019. Internet of smart city objects: A distributed framework for service discovery and composition. IEEE Access 7, 14434–14454.

Sun, L., Du, Q., 2018. A review of physical layer security techniques for Internet of Things: Challenges and solutions. Entropy 20 (10), 730.

Tariq, U., Ahmed, I., Bashir, A.K., Shaukat, K., 2023. A critical cybersecurity analysis and future research directions for the Internet of Things: A comprehensive review. Sensors 23 (8), 4117.

Turkle, S., 2006. Always-on/always-on-you: The tethered self. Handb. Mob. Commun. Stud..

Tushar, W., Yuen, C., Saha, T.K., Nizami, S., Alam, M.R., Smith, D.B., Poor, H.V., 2023. A survey of cyber-physical systems from a game-theoretic perspective. IEEE Access 11, 9799–9834.

Vermesan, O., Friess, P., Guillemin, P., Gusmeroli, S., Sundmaeker, H., Bassi, A., Jubert, I.S., Mazura, M., Harrison, M., Eisenhauer, M., et al., 2022. Internet of things strategic research roadmap. In: Internet of Things-Global Technological and Societal Trends from Smart Environments and Spaces to Green ICT. River Publishers, pp. 9–52.

Wang, J., Wu, L., Zeadally, S., Khan, M.K., He, D., 2021. Privacy-preserving data aggregation against malicious data mining attack for IoT-enabled smart grid. ACM Trans. Sens. Netw. (TOSN) 17 (3), 1–25.

Wang, Z., Zeng, H., 2010. Study on the risk assessment quantitative method of information security. In: 2010 3rd International Conference on Advanced Computer Theory and Engineering. ICACTE, 6, IEEE, pp. V6–529.

Waqdan, M., Louafi, H., Mouhoub, M., 2023a. A comprehensive risk assessment framework for IoT-enabled healthcare environment. In: Proceedings of the 20th International Conference on Security and Cryptography. pp. 667–672. http://dx.doi.org/10.5220/0012060900003555.

Waqdan, M., Louafi, H., Mouhoub, M., 2023b. An IoT security risk assessment framework for healthcare environment. In: 2023 International Symposium on Networks, Computers and Communications. ISNCC, IEEE, pp. 01–08.

Waqdan, M., Louafi, H., Mouhoub, M., 2025. A customizable security risk assessment framework using multi-attribute decision making for IoT systems. In: Proceedings of the 11th International Conference on Information Systems Security and Privacy - Volume 1. pp. 121–132. http://dx.doi.org/10.5220/0013081700003899.

Weisman, M., Kott, A., Ellis, J., Murphy, B., Parker, T., Smith, S., Vandekerckhove, J., Senapati, D., Bhagat, P., Karfa, C., et al., 2025. ACM Trans. Cyber-Phys. Syst. 9 (1).

Wheeler, E., 2011. Security Risk Management: Building an Information Security Risk Management Program from the Ground Up. Elsevier.

Wilson, C., 2008. Botnets, Cybercrime, and Cyberterrorism: Vulnerabilities and Policy Issues for Congress. LIBRARY OF CONGRESS WASHINGTON DC CONGRESSIONAL RESEARCH SERVICE.

Woodruff, J.M., 2005. Consequence and likelihood in risk estimation: A matter of balance in UK health and safety risk assessment practice. Saf. Sci. 43 (5–6), 345–353.

Wynn, J., Whitmore, J., Upton, G., Spriggs, L., McKinnon, D., McInnes, R., Graubart, R., Clausen, L., 2011. Threat Assessment & Remediation Analysis (TARA): Methodology Description Version 1.0. Tech. Rep., MITRE CORP BEDFORD MA.

Xiaojian, Z., Liandong, C., Jie, F., Xiangqun, W., Qi, W., 2021. Power IoT security protection architecture based on zero trust framework. In: 2021 IEEE 5th International Conference on Cryptography, Security and Privacy. CSP, IEEE, pp. 166–170.

Zahra, F.T., Bostanci, Y.S., Soyturk, M., 2023. Real-time jamming detection in wireless IoT networks. IEEE Access 11, 70425–70442.

Zhang, X., Xu, M., Su, J., Zhao, P., 2023. Structural models for fog computing based internet of things architectures with insurance and risk management applications. European J. Oper. Res. 305 (3), 1273–1291.